ТУСУР
TUSUR UNIVERSITY

Аспекты ИБ в рамках менеджмента непрерывности деятельности организации

Управление информационной безопасностью. Лекция 2.13

17 Аспекты информационной безопасности в рамках менеджмента непрерывности деятельности организации

Раздел включает в себя 2 категории и 4 меры обеспечения информационной безопасности:

17.1 Непрерывность информационной безопасности
Цель: Непрерывность обеспечения ИБ должна быть неотъемлемой частью систем менеджмента непрерывности деятельности организации.

- 17.1.1 Планирование непрерывности информационной безопасности
- 17.1.2 Реализация непрерывности информационной безопасности
- 17.1.3 Проверка, анализ и оценивание непрерывности информационной безопасности

17.2 Резервирование оборудования
Цель: Обеспечить уверенность в доступности средств обработки информации.

- 17.2.1 Доступность средств обработки информации

Планирование непрерывности информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Организация должна определить свои требования к ИБ и менеджменту непрерывности ИБ при неблагоприятных ситуациях, например во время кризиса или бедствия.

Организация должна определить, обеспечивается ли непрерывность ИБ в рамках процесса менеджмента непрерывностью бизнеса или в рамках процесса менеджмента восстановления после чрезвычайных ситуаций. Требования ИБ должны быть определены при планировании непрерывности бизнеса и восстановления после чрезвычайных ситуаций. При отсутствии формально утвержденных планов непрерывности бизнеса и восстановления после чрезвычайных ситуаций управление ИБ должно исходить из того, что требования ИБ в неблагоприятных ситуациях те же, что и при обычных условиях. В качестве альтернативы организация может провести анализ влияния на бизнес в разрезе аспектов ИБ, чтобы определить требования ИБ, которые применимы в неблагоприятных ситуациях.

Чтобы сократить время и затраты на дополнительный анализ влияния на бизнес, рекомендуется учитывать аспекты ИБ в рамках обычного анализа влияния на менеджмент непрерывности бизнеса или восстановления после чрезвычайных ситуаций. Это предполагает, что требования к непрерывности ИБ четко сформулированы в процессах менеджмента непрерывности бизнеса или восстановления после чрезвычайных ситуаций. Информацию о менеджменте непрерывности бизнеса можно найти в ИСО 27031, ИСО 22313 и ИСО 22301

Реализация непрерывности информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Организация должна установить, документировать, реализовать и поддерживать процессы, процедуры, а также меры для обеспечения требуемого уровня непрерывности ИБ при неблагоприятных ситуациях.

Организация должна обеспечить следующее:

a) наличие адекватной структуры управления по подготовке, реагированию и снижению последствий от неблагоприятных событий, включающей персонал, обладающий необходимым опытом, компетенциями и полномочиями;
b) утверждение ответственного персонала по реагированию на инциденты, обладающего необходимыми полномочиями и компетенциями, для управления инцидентами и обеспечения ИБ;
c) разработку и утверждение документированных планов, процедур реагирования и восстановления, подробно описывающих, как организация будет справляться с неблагоприятным событием и будет поддерживать ИБ на заранее определенном уровне, основанном на утвержденных руководством целях обеспечения непрерывности ИБ.

Реализация непрерывности информационной безопасности

ТУСУР
TUSUR UNIVERSITY

В соответствии с требованиями непрерывности ИБ организация должна установить, задокументировать, реализовать и поддерживать:

a) меры обеспечения ИБ в процессах обеспечения непрерывности бизнеса или восстановления после аварийных ситуаций, процедуры, вспомогательные системы и инструменты;
b) процессы, процедуры и изменения для поддержания существующих мер обеспечения ИБ во время неблагоприятных ситуаций;
c) компенсирующие меры для тех мер обеспечения ИБ, которые не могут поддерживаться во время неблагоприятной ситуации.

В контексте непрерывности бизнеса или восстановления после аварий могут быть определены конкретные процессы и процедуры. Информация, обрабатываемая в рамках этих процессов и процедур или поддерживающих информационных систем, должна быть защищена. Поэтому организация должна привлекать специалистов по ИБ при создании, внедрении и поддержке процессов и процедур обеспечения непрерывности бизнеса или восстановления после аварий.

Внедренные меры обеспечения ИБ должны оставаться работоспособными в неблагоприятных ситуациях. Если меры не могут продолжать выполнять свои функции по защите информации, следует определить, внедрить и поддерживать другие меры для обеспечения приемлемого уровня ИБ.

Проверка, анализ и оценивание непрерывности информационной безопасности

ТУСУР
TUSUR UNIVERSITY

Организация должна регулярно проверять установленные и реализованные меры по обеспечению непрерывности ИБ, чтобы обеспечить уверенность в их актуальности и эффективности при возникновении неблагоприятных ситуаций.

Организационные, технические, процедурные изменения или изменения в процессах как в контексте эксплуатации, так и непрерывности, могут привести к изменениям требований непрерывности ИБ. В таких случаях непрерывность процессов, процедур и мер обеспечения ИБ должна быть проанализирована с точки зрения изменений в требованиях.

Организации должны проверять непрерывность менеджмента ИБ путем:

a) осуществления и тестирования функциональности процессов, процедур и мер непрерывности ИБ для гарантии их соответствия целям обеспечения непрерывности ИБ;
b) осуществления и тестирования осведомленности и порядка управления процессами, процедурами и мерами непрерывности ИБ для гарантии того, что их выполнение соответствует целям обеспечения непрерывности ИБ;
c) анализа пригодности и эффективности мер непрерывности ИБ при изменении информационных систем, процессов, процедур и мер обеспечения ИБ или процессов и решений менеджмента непрерывности бизнеса/восстановления после аварий.

Проверка, анализ и оценивание непрерывности информационной безопасности

Проверка мер непрерывности ИБ отличается от общей проверки ИБ и должна проводиться вне рамок тестирования изменений. По возможности желательно интегрировать проверку мер непрерывности ИБ в проверку непрерывности бизнеса организации или проверку восстановления после аварийной ситуации.

Доступность средств обработки информации

Средства обработки информации должны быть внедрены с учетом резервирования, достаточного для выполнения требований доступности.

Организации должны определить требования бизнеса к доступности информационных систем. В тех случаях, когда доступность не может быть обеспечена существующей системной архитектурой, следует рассмотреть возможность добавления избыточности компонентам и архитектуре.

Там, где это применимо, обеспечивающие избыточность информационные системы должны быть проверены для гарантии того, что переключение с одного компонента на другой функционирует должным образом.

Внедрение избыточности может порождать риски нарушения целостности или конфиденциальности информации и информационных систем. Их необходимо учитывать при проектировании информационных систем.

Рассмотренные вопросы

Аспекты ИБ в рамках менеджмента непрерывности деятельности организации:

- Планирование и реализация непрерывности ИБ.

Почитать

- ГОСТ Р ИСО/МЭК 27002-2021

ТУСУР
TUSUR UNIVERSITY

Всем спасибо – все свободны,

если нет вопросов!